

Sorted (Auriq Wealth): internal security test report, 2026-09

Product: Sorted, by Auriq (the AI wealth dashboard, "ai-wealth-dashboard")
Company: AURIQ LTD
Report id: AURIQ-SEC-RPT-2026-09
Version: 1.0 candidate
Date: 2026-10-04
Classification: Confidential, prepared for Finexer
Author: AURIQ LTD, Information Security Manager: Kevin Maingi

1. Summary

AURIQ LTD performed an internal security assessment of the recorded scope and builds, mapped to selected OWASP ASVS 5.0.0, WSTG 4.2, API Security Top 10:2023, MASVS/MASTG 2.0.0, OAuth, MCP, and LLM security guidance. The report records executed tests, limitations, blockers, findings, severity, and retest status.

That is the reporting statement for this assessment, adapted from `docs/security/PENTEST-METHODOLOGY.md` section 11. Section 11 also says the assessment is complete, and that statement final, only once a separate reviewer has signed the coverage matrix and findings. That review is pending (section 10), which is why this document is a v1.0 candidate.

Headline. No Critical findings. Five High findings were raised, and fixes for all five are now in production.

- **A82, A83, A84, A91** (API and MCP) were fixed on `main` by 2026-09-22, shipped to production on 2026-09-27 (`release-20260927-0947`) and retested the same day (board item A112, `docs/security/pentest-runs/A112-2026-09-27/`). A83's `GET /connections` listing half and A91 were confirmed Fixed live. A82, A83's disconnect-before-delete half and A84 were confirmed Fixed by source read only: the live retest of that step (`API-15`) was Blocked when the supplied disposable test credential returned `401 Session expired` before any request reached the deletion path. That limitation stays open (section 6).
- **A121** (iOS biometric lock bypass) was found in device testing on 2026-09-27, fixed and integrated on 2026-09-29, shipped in `release-20261001-2038` , and retested on both phones on 2026-10-04 (`docs/security/pentest-runs/A60-2026-10-04/`): Pass.

The eleven first-round Medium and Low fixes (A74, A76, A80, A85, A86, A88, A89, A90, A92, A93, A95) in production from `release-20260927-0947` (2026-09-27) and were retested by A112 on the `release-20260927-1844` build: ten were confirmed Fixed (A74 and A90 on UAT, since the connector is not registered on production), and A80 was recorded Partially fixed, because the environment variable that enables its spend ceiling was unset on both production services that day. Enabling it is Kevin's operational decision.

The device round raised four further findings. A120 (Low, push registration survives logout) and A122 (Low, app-switcher snapshot shows figures) are remediated and retested on device on 2026-10-04. A118 (Medium, Android session token recoverable on disk after logout) has its server-side revocation in production, but the device re-check of on-disk residue has not been run. A119 (Medium, the debug build's WebView is remotely inspectable) is closed: debug build only, with the signed release APK verified on 2026-09-28 as not inspectable. Follow-ups A123 (token moved to platform secure storage, in production, device retest pending), A129 (Android `allowBackup` , open) and A138 (push re-registration after sign-in, intermittent, open) are remediation follow-ups, not new findings. Still open from the first round: A73, A77, A79, A81, A94 and the residual A106. Every finding is tracked individually in section 5.

The MCP connector is disabled in production today (`MCP_CONNECTOR_ENABLED` unset, board item A17), confirmed live 2026-09-23 by an anonymous `initialize` request returning 401 with no `WWW-Authenticate` challenge on both the Vercel-fronted path and the direct Railway host, while UAT advertises the challenge; A91, the MCP prompt-injection finding, is therefore not exploitable in production today. Enabling the connector in production is separately gated on Finexer's written design sign-off (board item F1), which remains open.

Coverage is 12 of 12 planned work packages executed, to the extent possible without a Mac or a rooted device (WP7b and WP8 ran live on real devices on 2026-09-27, and the fixes were retested on device on 2026-10-04; see section 4). The WP12 cross-model review is a recorded deviation: the Codex half was dropped by Kevin's decision of 2026-10-04, and only the audit by a separate Claude reviewer agent remains, pending (section 4 and section 10). Every severity in this report is therefore the judgement of the testing sessions and Kevin's sign-off, with the audit by a separate Claude reviewer agent still to come.

2. Scope, environments and rules of engagement

What was tested. The web shell (Vercel), the REST API (Railway), the OAuth 2.1 authorisation server, the MCP connector, the Android and iOS app shells (static analysis and live device testing), and the Finexer, TrueLayer, Stripe and OpenRouter integration boundaries. Full surface definitions are in `docs/security/pentest-scope-2026-09.md`.

Hosts.

Host	Role
<code>https://wealth.auriqltd.co.uk</code>	Production. The environment-of-record for almost every case in this round, per the rules-of-engagement record's third amendment (2026-09-20): production is the default environment once test identities are allow-listed there, not merely a fallback.
<code>https://uat.wealth.auriqltd.co.uk</code>	UAT. Retained as the only environment for OAuth (<code>OAUTH-02</code> through <code>OAUTH-10</code>) and MCP (<code>MCP-02</code> through <code>MCP-11</code>) cases, because <code>MCP_CONNECTOR_ENABLED</code> is off in production, so <code>backend/app/main.py</code> never registers those routers there; there is nothing on production for those specific cases to reach.

Builds. Each run's own manifest records the repository commit and deployment id under test at the time; see the per-work-package rows in section 4. No case in this round ran against a build later modified to pass a test it would otherwise have failed.

Test identities. Three pseudonymous identities only: PT-A (primary test user, controlled account and transaction data, a Finexer bank connection), PT-B (a second, isolated test user, used for cross-tenant checks), and PT-C (a disposable identity created by Kevin directly on production, used once for account-deletion testing then deleted). The real address behind each pseudonym lives only in a private, gitignored file (`.pentest-evidence/<run-id>/roe.env`), never in this report, the board, or any committed file. No real email address, name other than Kevin's, or recoverable credential appears anywhere in this report or its sources.

Dates. The rules-of-engagement record was signed 2026-09-20. The ten executed work packages ran between 2026-09-20 and 2026-09-21 (see section 4 for each run's exact start and end times), the device work packages (WP7b, WP8) on 2026-09-27, and the on-device retest on 2026-10-04. This report is dated 2026-10-04.

Authoriser. Kevin, in his role as the product's owner and Information Security Manager, is the sole authoriser, incident contact and stop authority named on the rules-of-engagement record (`docs/security/pentest-runs/roe-record.md`), signed 2026-09-20, quoted there verbatim: "I agree with the details in the pentest, and you can take this attestation as my signature."

Tester and reviewer roles. The work packages WP1 to WP7a and WP9 to WP11 were performed by this project's own AI agent sessions (Claude and Codex). The device packages (WP7b, WP8) and the 2026-10-04 retest were performed by Kevin on his own phones, guided and recorded by a Claude session. Each run's own manifest names its tester and records its review status; review of the evidence is pending (see section 10).

Techniques and caps. Permitted tools, numeric caps (one manual request at a time, one harmless canary per class, one controlled cross-tenant object per class), and hard bans (no file reads outside the target application, no command execution against a target, no production entitlement change, no real money movement, no payment initiation, no bank-credential capture) are recorded in full in the rules-of-engagement record and were not exceeded in any run.

3. Methodology and standards

Testing followed `docs/security/PENTEST-METHODOLOGY.md`, a reconciliation of two separately produced draft methodologies (Claude's and Codex's) into one agreed test catalogue, evidence format and severity rubric (board item A43). It layers several standards, each scoped to the surface it actually fits, rather than claiming a single blanket certification against any one of them:

Standard	Applied to
OWASP ASVS 5.0.0 (Level 2 baseline, risk-selected Level 3 in named control families)	Requirements backbone across every surface
OWASP WSTG 4.2	The browser-delivered web shell and <code>/design</code> preview routes
OWASP API Security Top 10:2023	The REST API and the API-shaped parts of OAuth, MCP, and the Finexer/TrueLayer/Stripe boundaries
OWASP MASVS/MASTG 2.0.0	The Android app shell (static analysis and on-device testing)
OAuth 2.0 Security BCP, RFC 9700	The OAuth 2.1 authorisation server
The MCP specification (version <code>2025-06-18</code> , as declared by the server)	The MCP connector
OWASP Top 10 for LLM Applications 2025	Penny and the OpenRouter integration
FIRST CVSS 4.0	Optional technical-severity colour on a confirmed finding, never the severity gate itself
NIST SP 800-115	The rules-of-engagement, execution lifecycle, and the run-manifest/per-test-record/finding-record evidence structure this report draws on

This is an assessment mapped to selected ASVS requirements and WSTG/MASTG procedures. It is not, and must never be described as, "OWASP certified", "ASVS compliant", or a complete ASVS verification. Severity uses `SECURITY.md` section 3's four-band scale (Critical, High, Medium, Low), and the remediation-SLA targets in section 3a (reproduced in section 8 below).

4. Coverage matrix

One row per work package. Case counts and results are taken from each run's own manifest and per-case records under `docs/security/pentest-runs/<run-id>/`. Where a single case recorded a mixed outcome across sub-components (for example, one property held and another did not), the row below counts it once, by its recorded headline verdict; the finding register in section 5 and the underlying per-test record carry the full detail.

WP	Run id	Board item	Dates (UTC)	Cases	Pass	Fail	Blocked	N/A	Not run
WP1: Web shell and <code>/design</code> routes	A48-2026-09-20	A48	2026-09-20, 15:14-16:02Z	12	7	3	2	0	0
WP2: API inventory, credentials, rate limits, error handling, CORS	A49-2026-09-21	A49	2026-09-21, 05:47-06:05Z	7	3	4	0	0	0
WP3: API tenant and object authorisation, account deletion	A50-2026-09-20	A50	2026-09-20, 17:45-20:18Z	3	2	1	0	0	0
WP4: API input handling, uploads, business-logic ordering	A51-2026-09-20	A51	2026-09-20, 20:40-21:21Z	6	5	1	0	0	0
WP5: OAuth 2.1 authorisation server	A52-2026-09-20	A52	2026-09-20, 12:17-12:30Z	10	8	2	0	0	0
WP6: MCP connector	A53-2026-09-21	A53	2026-09-21, 05:49-05:55Z	11	8	2	0	1	0
WP7a: Android app shell, static analysis	A54-2026-09-20	A54	2026-09-20, 17:44-17:58Z	3	0	3	0	0	0
WP7b: Android app shell, dynamic (device)	A55-2026-09-27	A55	2026-09-27	8	4	4	0	0	0
WP8: iOS app shell, dynamic (device)	A56-2026-09-27	A56	2026-09-27	5	2	3	0	0	0
WP9: Finexer and TrueLayer boundary	A57-2026-09-20	A57	2026-09-20, 21:38-21:46Z	12	5	2	2	0	3
WP10: Stripe fail-closed boundary	A58-2026-09-21	A58	2026-09-21, 05:40-05:56Z	5	4	0	1	0	0
WP11: OpenRouter and Penny trust boundary	A59-2026-09-20	A59	2026-09-20, 18:20-18:45Z	8	6	2	0	0	0
WP12: Retest record and review	A60-2026-10-04	A60	2026-10-04	see the retest records below the table	n/a	n/a	n/a	n/a	n/a
Total (WP1-WP11 plus WP7b/WP8, executed)				90	54	27	5	1	3

WP4 note. A51-2026-09-20 also records a mandatory `IDENTITY-GATE` assertion (added after incident A78). It is a pre-run check, not a catalogue case, so it is not counted: WP4 is six catalogue cases (`API-06` , `API-07` , `API-08` , `API-10` , `API-13` , `API-14` ; five Pass, one Fail).

WP9 note. WP9 is twelve cases (`FIN-01` to `FIN-06` , `TL-01` to `TL-06`). `TL-01` , `TL-03` and `TL-05` were Not run (TrueLayer is being removed from production, board item A67; see section 6), so they are in the Not run column, not N/A. The one N/A in the total is `MCP-10` in WP6.

Totals, how derived. Each row was recomputed from the `Result` field of every case record in that run's `records.md` , counting a mixed case once by its recorded headline verdict (the rule stated above the table). Cases: $12 + 7 + 3 + 6 + 10 + 11 + 3 + 8 + 5 + 12 + 5 + 8 = 90$. Pass 54, Fail 27, Blocked 5, N/A 1, Not run 3 ($54 + 27 + 5 + 1 + 3 = 90$). The WP12 retest records are not catalogue cases and are not counted.

WP3 note. The A50-2026-09-20 run record contains a fourth section, `API-15` , attempt 1, marked VOID because it ran against the wrong identity (incident A78, tracked p1 on the board): it is excluded from the case count above, and the retained `API-15` result is the valid second attempt, run against genuine PT-C after the mandatory identity gate was corrected.

WP7a note. All three cases in WP7a (`AND-01` 's backup-flag sub-result, the static half of `AND-08` , and `MOB-01`) recorded Fail as their headline verdict, but each is a pre-documented, already-known gap (dated back to its original documentation commit, per the methodology's own "backdate the acknowledge clock" rule), re-confirmed live against the built artefact rather than newly discovered; `AND-01` and the static half of `AND-08` each also carry a Pass on a distinct sub-component within the same case (exported-component protection, and callback payload exposure, respectively). None of the three raised a fresh board item: `AND-01` and `AND-08` are pre-documented, accepted design gaps recorded in `PENTEST-METHODOLOGY.md` section 6.5.1 and remain open; `MOB-01` tracks to `A77` .

WP7b: executed 2026-09-27. Dynamic Android testing ran live on Kevin's own device against the production-pointed debug APK (package `co.uk.auriqltd.sorted` , SHA-256 `73bab9744ae166a94a35bcf1c05bbfc33605f225d39efd5f8e979b77b7c3fc3e`), guided and recorded by a Claude session; see `docs/security/pentest-runs/A55-2026-09-27/` for the run manifest and per-test records. Eight cases ran (`AND-02` through `AND-09`); four Passed and four Failed. Two Fails are pre-documented, already-known gaps re-confirmed live (the storage/backup half of `AND-02` and the scheme-exclusivity half of `AND-08`), not fresh findings. Three fresh findings were raised: A118 (Medium, post-logout session-token residue on disk, `AND-02`), A119 (Medium, the debug build's WebView is remotely inspectable behind the lock overlay, `AND-09`), and A120 (Low, push device registration survives logout, `AND-07` , later confirmed cross-platform on the iOS run too). A handful of sub-steps needing root, Frida, or a scripted instrumentation harness were not tested in this round, because none was available; they are listed in the "Deferred" table at the end of `A55-2026-09-27/records.md` and carried in section 6 as Blocked, not passed.

WP8: executed 2026-09-27. Dynamic iOS testing ran live on Kevin's own iPhone against the production TestFlight build, as test identity PT-A, guided and recorded by a Claude session; see `docs/security/pentest-runs/A56-2026-09-27/` for the run manifest and per-test records. Five cases ran (`IOS-02` partial, `IOS-03` , `IOS-04` , `IOS-05` , `IOS-07`); two Passed and three Failed. The headline result was **A121** (High, `IOS-03`), now remediated and retested (section 5). `IOS-07` step 4 folded into A121 as the same lock-overlay-reachable condition seen via a notification tap rather than a separate finding; its step 6 confirmed A120 (first raised on the Android run above) also applied to APNs registration. `IOS-02` (partial) raised A122 (Low, the app-switcher/recents snapshot showed live financial figures on both platforms even with the lock enabled). `IOS-01` , `IOS-06` , the Keychain/file-protection halves of `IOS-02` , and the instrumented halves of `IOS-04` / `IOS-05` were not tested in this round, since they need a Mac, a built IPA, or a second signed app that was not available; they are carried in section 6 as Blocked, not passed.

WP12: retest record executed 2026-10-04, review pending. Kevin retested the A120, A121 and A122 fixes on his own Android phone (Pixel 10 Pro XL, Android 17) and iPhone (iOS 18.7) against production, guided and recorded by a Claude session; see `docs/security/pentest-runs/A60-2026-10-04/` for the run manifest and per-test records. The run used Kevin's own owner account rather than the pseudonymous identity PT-A, a deviation from the runbooks that Kevin authorised on 2026-10-04; individual checks are not attributed to the run's two sessions (production releases `decdd7938` and `c34332b6`) except where server logs place them. Both builds contain the A120, A121 and A122 fixes. Results:

Retest record	Finding	Result
Push registration after sign out everywhere (<code>AND-07</code> , <code>IOS-07</code> step 6)	A120, logout half	Pass, both phones
Push registration resumes after sign in	A120, resume half	Fail on one earlier Android attempt (tracked as A138); Pass on re-run, both phones
Lock with the app open (<code>IOS-03</code> , Android equivalent <code>AND-03</code>)	A121	Pass, both phones
Cold start from a notification tap with the lock on	A121	Pass, both phones
App-switcher cover (<code>IOS-02</code> snapshot sub-step, Android equivalent)	A122	Pass, both phones

These are retest records, not new catalogue cases, so they are not counted in the matrix totals above. Not retested in this run: `AND-02` token-at-rest and `adb backup` (needs a debug build; the backup half also waits on A129), A123 staying signed in across restarts (result pending from Kevin), and `AND-09` (A119 was closed by static verification of the signed release APK on 2026-09-28). See section 6.

WP12 deviation (recorded). `PENTEST-METHODOLOGY.md` section 9 specifies a cross-model review: a Codex session auditing every Claude-run work package's Fail evidence, and a Claude session auditing every Codex-run package. Kevin decided on 2026-10-04 to drop the Codex half. The review that remains is a separate Claude reviewer agent's audit of the evidence, which is a separate step that has not yet run (section 10, "WP12 review: pending"). Consequence, stated plainly: the work packages run by Claude sessions have not been reviewed by a second model, so every severity in this report is the judgement of the testing sessions, a separate Claude reviewer agent once that audit runs, and Kevin's sign-off.

Two further gaps recorded on the coverage side, not visible as a work package row above: `FIN-06` (webhook payload retention confirmation) and the accepted-delivery live halves of `FIN-01` and `TL-02` could not be completed within WP9, because this testing has no production database read path and no provider-approved sandbox consent exists; these are recorded Blocked within WP9's own tally above, not silently passed.

5. Findings register

Severity bands are `SECURITY.md` section 3's Critical / High / Medium / Low / Informational. "Status" reflects the board (`TOD0.md`) state as of 2026-10-04. "Production status" and "retest status" are stated per the rule established in section 1: nothing here is "remediated" or "closed" until it is on production and retested; where only part of that is true, the row says which part. For A118 to A123 the commit shown is the integrate (merge) commit on `main` .

Severity bands. Severities use `SECURITY.md` section 3's four bands (Critical, High, Medium, Low). The Informational band comes from the testing methodology (`PENTEST-METHODOLOGY.md` section 8.3): a verified fact or hardening opportunity with no demonstrated adverse outcome and no P1-P4 SLA, used here for A94. A76 is listed as Low below, although the `A48-2026-09-20 DSGN-04` record scored the same crawlable-preview exposure Informational (a business-confidentiality risk, not a security-boundary breach); the register carries the more conservative Low, and the board's rating governs.

High

Id	Title	Affected surface	Status	Fix commit	Production status	Retest status
A82	Account deletion never revokes the Finexer consent first, orphaning it at the provider	<code>DELETE</code> account, retention/deletion path	Fixed on main	<code>2488763e</code>	Deployed 2026-09-27 (<code>release-20260927-0947</code> , confirmed still present in <code>release-20260927-1844</code>)	Source-confirmed Fixed 2026-09-27 (A112); live retest Blocked by an already-expired test credential
A83	<code>GET /connections</code> does not list live Finexer connections, hiding the connection A82's disconnect-first step needs	Connections listing route	Fixed on main	<code>c35ac008</code>	Deployed 2026-09-27 (<code>release-20260927-0947</code> , confirmed still present in <code>release-20260927-1844</code>)	Listing half confirmed Fixed live 2026-09-27 (A112); disconnect-before-delete half source-confirmed Fixed only, live retest Blocked (same as A82)
A84	A deleted account's session token is not invalidated and remains usable for up to 7 days, including for writes that can reattach if the account is recreated with the same email	Session/auth lifecycle	Fixed on main	<code>40fed391</code>	Deployed 2026-09-27 (<code>release-20260927-0947</code> , confirmed still present in <code>release-20260927-1844</code>)	Source-confirmed Fixed 2026-09-27 (A112); live retest Blocked, same as A82
A91	MCP output masking is structural only and never sanitises kept field content; an instruction-shaped merchant/category/insight string reaches the connecting assistant unmodified (prompt-injection surface)	MCP connector output masking	Fixed on main	<code>9c5b7ef9</code>	Deployed 2026-09-27 (<code>release-20260927-0947</code> , confirmed still present in <code>release-20260927-1844</code>); connector itself is off in production (A17), so not exploitable there today	Confirmed Fixed live 2026-09-27 (A112), tested on UAT since the connector is not registered on production
A121	The iOS biometric privacy lock was bypassable: with the lock engaged (cold start or via a notification tap), the nav bar and Penny suggestion chips were tappable behind the visual overlay, and a chip tap rendered live safe-to-spend and upcoming-bills figures with no authentication. Android's equivalent overlay held	iOS lock overlay / <code>BiometricLock</code> , nav bar, Penny chips	Remediated: fix integrated 2026-09-29	<code>eae3207e</code> (integrate commit)	In production (first shipped in <code>release-20261001-2038</code>)	Retested on device 2026-10-04 (<code>A60-2026-10-04</code>): Pass on both phones, app open and cold start from a notification tap

A82. WP3's live account-deletion case (`API-15` , run `A50-2026-09-20`) found that `erase_user` deletes every local trace of an account but never calls a bank-connection disconnect first; the upstream Finexer consent is left live and orphaned. The fix inserts a disconnect-before-delete step ahead of the existing local erase, so the provider-side consent is revoked as part of account deletion rather than left dangling. Verified so far by the regression tests added alongside the fix commit. The retest ran 2026-09-27 (board item A112, disposable identity PT-C, production): the disconnect-then-delete procedure itself was Blocked, the supplied PT-C credential was already rejected (`401 Session expired`) on every pre-state read before the deletion call ran, so the live property could not be exercised. Source read of `backend/app/services/retention.py::erase_user / disconnect_connection` confirmed the disconnect-before-erase ordering is present as released; a follow-up live pass with a freshly issued PT-C credential is still owed to confirm it live.

A83. The same run found that `GET /connections` only lists TrueLayer connections, never Finexer ones, which meant a caller (including the account-deletion flow A82 needed to fix) had no reliable way to discover a live Finexer connection to disconnect. The fix adds Finexer connections to that listing. Verified so far by the regression tests added with the fix. The retest ran 2026-09-27 (board item A112, production, PT-A): `GET /connections` returned both live Finexer connections correctly, confirmed Fixed live. The disconnect-before-delete half is covered by the A82 record above (source-confirmed only, live retest Blocked).

A84. The same run's token-invalidation half found that a deleted account's bearer session token kept authenticating reads and writes for up to seven days after deletion, and that a write against a deleted account's identifiers could reattach if the account was later recreated with the same email. The fix invalidates the session token as part of account deletion. Verified so far by the regression tests added with the fix. The retest ran 2026-09-27 (board item A112, disposable identity PT-C, production) but could not exercise the live before/after property: the supplied PT-C credential was already rejected (`401 Session expired`) before any deletion call was made, so no token survived a live deletion to test against. Source read of `backend/app/core/session_revocation.py::revoke_sessions / is_revoked` and `backend/app/routers/profile.py::delete_account` confirmed the revoke-before-erase ordering is present as released; a follow-up live pass with a freshly issued PT-C credential is still owed to confirm it live.

A91. WP6's MCP-06 case found that `app/services/mcp_mask.py` drops fields by shape only and never inspects or sanitises the content of the fields it keeps, so an instruction-shaped string placed in a merchant name, recurring-series description, or insight trigger (all provider-supplied text a user does not fully control) would reach a connected external assistant unmodified: a live prompt-injection surface with no content-level mitigation. The fix adds content-level sanitisation to the masking layer. Verified so far by the regression test added with the fix, run against the affected code path directly. The connector is off in production by design (MCP_CONNECTOR_ENABLED unset, board item A17), confirmed live 2026-09-23 (an anonymous `initialize` request returns 401 with no `WWW-Authenticate` challenge on both the Vercel-fronted path and the direct Railway host, unlike UAT, which advertises the challenge), so this finding has no production attack surface today; it does have one on UAT, where the connector is enabled. It must be fixed and retested before the connector is enabled in production, which is separately gated on Finexer's written design sign-off (board item F1, still open). The retest ran 2026-09-27 (board item A112, UAT, since the connector is not registered on production): a canary goal named with an instruction-shaped string was returned by the `get_goals` MCP tool with its `name` field replaced by the fixed marker, confirming Fixed live. This does not by itself retest against production, since the connector has no route there today; that check is still owed once F1's design is agreed and the connector is enabled in production.

A121. WP8's IOS-03 case (A56-2026-09-27) found that, with the biometric privacy lock engaged, whether from a cold start or by tapping a notification, the nav bar and Penny suggestion chips remained tappable behind the visual lock overlay, and tapping a chip rendered live safe-to-spend and upcoming-bills figures with no authentication. It needed only physical possession of an already-locked, previously-signed-in phone. Android's own lock overlay held under the equivalent reproduction (A55-2026-09-27, AND-03). Per PENTEST-METHODOLOGY.md section 3.5 it met the stop-condition bar for a repeatable, previously undocumented High finding. The fix was integrated on `main` on 2026-09-29 (eae3207e) and first shipped in `release-20261001-2038`. It was retested on device on 2026-10-04 (A60-2026-10-04) on both phones: with the app open and the lock engaged, the nav bar is not visible and nothing behind the lock can be reached (Pass); with the app fully closed and a push notification tapped, the app opens to the lock screen and the lock cannot be bypassed (Pass). Status: remediated and retested. The 2026-10-04 evidence is Kevin's own on-device observation, recorded without screenshots.

A118. WP7b's AND-02 case found that after an in-app logout the Android session token value was still recoverable from the WebView's append-only Local Storage log on disk (on a debug build, via `adb run-as`), and that no server-side logout existed, so a recovered token stayed valid for its full 7-day expiry. The fix added a server-side logout that revokes every session for the account (sign out everywhere), integrated on `main` on 2026-09-29 and in production since `release-20261001-2038`. A deliberately cosmetic alternative (overwriting the key before removing it) was assessed and not built, because it leaves the original record recoverable. The on-disk residue itself is addressed by follow-up A123 (token moved to platform secure storage). Status: server-side revocation in production; the device re-check of on-disk residue has not been run (it needs a debug build; see section 6).

A119. WP7b's AND-09 case found that on the Android debug build the WebView is remotely inspectable, so the authenticated DOM was reachable behind the lock overlay. The accessibility tree and TalkBack did not leak financial content while locked. On 2026-09-28 the signed release APK was decompiled and verified: the manifest carries no `debuggable` attribute and Capacitor's WebView debugging resolves to false for that artefact, so the release build is not remotely inspectable. Status: closed, debug build only. This closure rests on static verification of the release artefact and was not re-run on a device.

A120. WP7b's AND-07 case, confirmed on iOS by IOS-07 step 6, found that the device push registration survived in-app logout, so a signed-out device kept receiving push notifications. The fix drops every web-push, FCM and APNs registration for the user at logout, with the client unregistering before the revoke, and re-registers on sign-in. It was integrated on `main` on 2026-09-29 and shipped in `release-20261001-2038`. Retested on device on 2026-10-04 (A60-2026-10-04): after sign out everywhere, test pushes no longer arrived on either phone (Pass). The resume half is recorded in both directions: on Android, earlier that day, the Settings test push returned "No device is registered yet" until the app was relaunched (Fail on that attempt, tracked as follow-up A138, intermittent); on a later re-run, on both phones, sign out, sign in and a test push with no restart delivered (Pass). Status: remediated and retested, with A138 open.

A122. The 2026-09-27 device rounds found that the app-switcher or recents snapshot showed live financial figures even with the biometric lock enabled, on both platforms (tapping back in correctly required unlock, so this was not an entry bypass). The fix covers the app while it is backgrounded, integrated on `main` on 2026-09-29 and shipped in `release-20261001-2038`. Retested on device on 2026-10-04 (A60-2026-10-04): with the lock on, the app-switcher card is covered and shows no figures on both phones, and on Android a screenshot is blocked while the lock is on (Pass). Status: remediated and retested. As for A121, the 2026-10-04 evidence is Kevin's own on-device observation, without screenshots.

Medium

Id	Title	Status	Fix commit	Production status	Retest status
A73	OAuth consent page under-emphasises the true redirect host relative to the connector's self-reported name	Open	none	N/A	Pending
A74	Refresh-token rotation does not cascade-revoke the sibling access token from the same grant	Fixed	eac94538	In production from <code>release-20260927-0947</code>	Confirmed Fixed live 2026-09-27 (A112), on UAT since the OAuth server is not registered on production

Id	Title	Status	Fix commit	Production status	Retest status
A79	Bank narrative text sent to OpenRouter for categorisation and Penny read tools, unredacted	Open	none	N/A	Pending
A88	Finexer consent callback accepted a missing <code>state</code> parameter	Fixed	683078c8	In production from <code>release-20260927-0947</code>	Confirmed Fixed 2026-09-27 (A112), by source read; the live differential could not be exercised without touching a real consent
A89	Webhook path-secret comparison was not constant-time	Fixed	f4983f8e	In production from <code>release-20260927-0947</code>	Confirmed Fixed 2026-09-27 (A112), by source read, with live behaviour unchanged as expected
A92	Production's proxy chain did not strip a caller-supplied <code>X-Real-IP</code> / <code>X-Forwarded-For</code> header, so IP-keyed rate limits were bypassable	Fixed	d5fbdfe1	In production from <code>release-20260927-0947</code> , after its gate A110 cleared	Confirmed Fixed live 2026-09-27 (A112), 3 requests
A95	<code>GET /logo/{domain}</code> carried no rate limit at all	Fixed	aeadb348	In production from <code>release-20260927-0947</code>	Confirmed Fixed 2026-09-27 (A112), by source read; the bounded live burst stayed under the configured limit
A118	After logout, the Android session token value is still recoverable on disk (LevelDB append-only storage), and no server-side logout existed, so a recovered token stayed valid for its full 7-day expiry	Remediated in part: server-side logout revocation (sign out everywhere), integrated 2026-09-29	24e79129 (integrate commit)	In production (first shipped in <code>release-20261001-2038</code>)	Server-side revocation in production. The device re-check of on-disk residue (<code>AND-02</code>) has not been run; the underlying storage root cause is addressed by follow-up A123
A119	On the Android debug build the WebView is remotely inspectable, and the authenticated DOM plus Capacitor bridge are reachable behind the lock overlay	Closed 2026-09-28: debug build only	none (no code change)	N/A, debug build only	The signed release APK (SHA-256 <code>554d083b3de1228a60a1a072a4937dfedf8adc6ffa23701dcbe14dee7107455e</code>) was decompiled and verified not remotely inspectable; closed by static verification, not by a device retest

Low

Id	Title	Status	Fix commit	Production status	Retest status
A76	<code>/design/*</code> preview routes were publicly indexable, no <code>robots.txt</code> / <code>X-Robots-Tag</code>	Fixed	e7621167	In production from <code>release-20260927-0947</code>	Confirmed Fixed live 2026-09-27 (A112)
A77	Native-purchase <code>X-Client-Platform</code> header check can be bypassed by omitting it (billing not live)	Open	none	N/A	Pending

Id	Title	Status	Fix commit	Production status	Retest status
A80	No global/service-wide OpenRouter spend ceiling, only a per-user monthly allowance	Partially fixed	7bea0094	In production from release-20260927-0947	Partially fixed (A112, 2026-09-27): the ceiling mechanism is in code, but the environment variable that enables it was unset on both production services that day, so no ceiling was enforced. Enabling it is Kevin's operational decision; its current state was not re-checked for this report
A81	Per-user LLM allowance check fails open, not closed, on an internal lookup error (documented, deliberate trade-off)	Open	none	N/A	Pending
A85	PATCH /preferences had no optimistic-concurrency check and accepted an unadvertised field (mass assignment)	Fixed	4b866395	In production from release-20260927-0947	Confirmed Fixed live 2026-09-27 (A112)
A86	Commitment state machine allowed out-of-order transitions, no create-time idempotency check	Fixed	1f8a318d	In production from release-20260927-0947	Confirmed Fixed live 2026-09-27 (A112)
A90	MCP initialize handler never validated or negotiated the client's requested protocol version	Fixed	141b057c	In production from release-20260927-0947	Confirmed Fixed 2026-09-27 (A112): live on UAT (envelope validation), source review (version negotiation)
A93	Unhandled NUL byte in a search query parameter crashed one endpoint with a 500 (no data leaked)	Fixed	4e0093e0	In production from release-20260927-0947	Confirmed Fixed live 2026-09-27 (A112)
none (no board item)	AND-08 scheme-exclusivity: Android gives no OS-level exclusivity for the bare wealthdash:// custom scheme, so a competing app can be offered alongside Sorted in a disambiguation dialog (found statically in A54-2026-09-20, confirmed live in A55-2026-09-27). The callback carries no code, token or account identifier, so the practical exploit path is closed off	Open (pre-documented design gap; acknowledge clock 2026-09-18; no remediation short of a verified https:// App Link)	none	N/A	Confirmed live 2026-09-27 (Fail, Low); not re-raised as a new item
A120	Push device registration survived logout on both Android (FCM) and iOS (APNs)	Remediated: sign out everywhere drops every push registration server-side, integrated 2026-09-29	44311669 (integrate commit)	In production (first shipped in release-20261001-2038)	Retested on device 2026-10-04 (A60-2026-10-04): logout half Pass on both phones; resume-after-sign-in half Pass on re-run, after one earlier Android Fail tracked as follow-up A138
A122	The app-switcher/recents snapshot showed live financial figures even with the biometric lock enabled, on both iOS and Android	Remediated: privacy cover while backgrounded, integrated 2026-09-29	bdbda0af (integrate commit)	In production (first shipped in release-20261001-2038)	Retested on device 2026-10-04 (A60-2026-10-04): Pass on both phones; screenshot also blocked on Android while the lock is on

Informational

Id	Title	Status	Fix commit	Production status	Retest status
A94	Dead, unreachable authorisation branch in current_user for an out-of-scope bot credential; access is still correctly denied elsewhere, not itself a weakness	Open	none	N/A	N/A, not a weakness

Residual follow-up disclosed alongside these findings

Id	Title	Status	Fix commit	Production status	Retest status
A106	Finexer consent revoke failure during a Finexer outage is swallowed and the local consent doc is deleted anyway, orphaning the consent with no record to retry from	Open	none	N/A	Pending

A106 is not itself one of this round's pentest findings; it is a follow-up gap identified in A82's own fix (the disconnect-then-delete ordering A82 introduced still has no retry path if the remote revoke call fails partway through, for example during a Finexer outage). It is disclosed here because it sits directly on the same account-deletion lifecycle as A82, A83 and A84 and is still open.

Remediation follow-ups (not new pentest findings)

Id	Title	State
A123	Move the native session token out of WebView <code>localStorage</code> into platform secure storage (Keychain on iOS, Keystore-backed storage on Android); the root cause behind A118	In production (integrated 2026-09-29, <code>9c11702c</code> , first shipped in <code>release-20261001-2038</code>); device retest pending
A129	The Android manifest sets <code>android:allowBackup=true</code> , so app data can be captured by adb or cloud backup	Open
A138	Native push does not always re-register after sign-in (seen once on the Android APK on 2026-10-04; a later sign-in worked without a restart)	Open, intermittent

These came out of the remediation work for A118 and A120 and from the 2026-10-04 retest. They are tracked on the board as follow-ups and are not counted among this round's findings.

6. Blocker and limitation register

Blocker or limitation	Detail	Status
<code>API-15</code> destructive half (A82, A83's disconnect-before-delete half, A84)	The live account-deletion retest on production (A112, 2026-09-27) was Blocked: the supplied disposable credential was already rejected (<code>401 Session expired</code>) before the deletion call, so nothing was deleted or mutated. The fix is confirmed present by source read only	Blocked live, source-confirmed Fixed only; owner Kevin (a freshly issued, pre-verified credential would close it)
<code>FIN-06</code> (webhook payload retention/TTL)	No production database or admin-API read path exists for this testing session to confirm live payload retention behaviour	Blocked, unresolved; owner Kevin (provide a scoped read path, or accept as not tested)
<code>FIN-01</code> and <code>TL-02</code> , accepted-delivery live halves	No Finexer-approved sandbox or test consent exists, and no TrueLayer-equivalent sandbox/test connection exists, to safely drive a live accepted-delivery webhook	Blocked, unresolved; owner Kevin (obtain a provider sandbox, or accept as not tested)
<code>OPEN_SIGNUP</code> window on production (2026-09-19)	A roughly 36-minute window during which production's normal Google/Apple-identity allow-list gate was relaxed to create PT-A and PT-B, then closed (board item A63). The post-window check for unexpected registrations during that window was deliberately not run: this session's own permission boundary declined the read, and Kevin judged it unnecessary at the time given the gate admitted only a verified Google or Apple identity throughout, never anonymous registration	Not retrospectively checked; available to Kevin if he wants the count run later
Device testing, iOS sub-steps not tested in this round	<code>IOS-01</code> , <code>IOS-06</code> , the Keychain and file-protection halves of <code>IOS-02</code> , and the instrumented halves of <code>IOS-04</code> and <code>IOS-05</code> need a Mac, a built IPA or a second signed app, none of which was available	Not tested in this round; carried as Blocked, never as passed
Device testing, Android sub-steps not tested in this round	The sub-steps listed in the "Deferred" table at the end of <code>docs/security/pentest-runs/A55-2026-09-27/records.md</code> need a rooted device, Frida or a scripted instrumentation harness, none of which was available	Not tested in this round; carried as Blocked, never as passed
<code>AND-02</code> token-at-rest and <code>adb backup</code> re-check (A118, A123)	Not retested on 2026-10-04: it needs a debug build to run <code>adb run-as</code> and a backup extraction, and the backup half also waits on open item A129 (Android <code>allowBackup</code>)	Not tested since the fixes shipped; owner Kevin
A123 session persistence across app restarts	Whether a signed-in user stays signed in across restarts on the new builds: result pending from Kevin (<code>A60-2026-10-04/records.md</code> , "Pending result")	Pending
<code>WEB-03</code> (token-in-URL redirect timing)	Blocked in <code>A48-2026-09-20</code> : all 8 live attempts on production were intercepted by Vercel's bot-verification challenge before the app mounted, so no clean observation of the fast-strip behaviour was obtained. Source review supports a synchronous strip before the validate call, but that is not what the case asks for	Blocked; owner Kevin; decision: retest recommended once production browser access is stable, or with a real non-headless browser session; not credited as Pass
<code>WEB-05</code> (cache-clearing across account switch)	Blocked in <code>A48-2026-09-20</code> : the case exists to catch a live rendering gap that code review cannot see, and no live render was possible for the same reason. <code>AuthProvider.tsx</code> <code>logout()</code> was source-reviewed only	Blocked; owner Kevin; decision: retest recommended on the same terms as <code>WEB-03</code> ; not credited as Pass

Blocker or limitation	Detail	Status
WEB-02 , storage-inspection sub-component	Inconclusive in A48-2026-09-20 : the one completed attempt landed during a Vercel availability event, so the observed clearing is explained by that event and neither confirms nor contradicts the claim. The tamper and rejection half is Pass. lib/auth.ts was code-reviewed as supporting, non-live evidence	Inconclusive; owner Kevin; decision: retest with a real browser session; no finding raised
AND-04 , user-CA trust leg	Inconclusive in A55-2026-09-27 : Android would not establish the mitmproxy user CA as trusted on the test device, so the live comparison could not run. The fail-closed leg (no CA) is Pass. This leg is settled by static reading only: no android:networkSecurityConfig at target SDK 36 means the platform default (user CAs not trusted) applies (A54-2026-09-20 , AND-01)	Inconclusive; owner Kevin; decision: accepted on the static reading, with a live retest only if a device that can establish a user CA is available; no finding raised
Cross-model review (WP12), Codex half	Dropped by Kevin's decision of 2026-10-04 (see section 4); the review that remains is a Claude reviewer's audit, pending (section 10)	Recorded deviation; not a gap that will be closed
TrueLayer live cases (TL-01 , TL-03 , TL-05 , and TL-04 's live-write half)	Not run: TrueLayer is being removed from production (board item A67), and Kevin's 2026-09-20 board note on A57 scoped these out. They are recorded Not run, not Pass, Fail or N/A	Not run; owner Kevin; decision: not run per that note, to be revisited only if TrueLayer is not removed

7. MCP connector production status

The MCP connector is disabled in production by design: the MCP_CONNECTOR_ENABLED environment variable is unset on the production Railway service, so backend/app/main.py's _routers() never registers the OAuth authorisation-server routes or the MCP connector routes there at all (board item A17). This was re-confirmed live on 2026-09-23: an anonymous initialize request to the connector returns 401 with no WWW-Authenticate challenge header, on both the Vercel-fronted path (https://wealth.auriqltd.co.uk) and the direct Railway host, whereas the equivalent request against UAT (https://uat.wealth.auriqltd.co.uk , where the connector is enabled) does advertise the challenge. This absence of a challenge header on production is the decisive signal that the connector is genuinely unregistered there, not merely returning a generic authentication failure for a route that exists.

Both cases that specifically test this absence, OAUTH-01 and MCP-01 , Passed (section 4, WP5 and WP6). Every other OAuth and MCP case in this round (OAUTH-02 through OAUTH-10 , MCP-02 through MCP-11) ran on UAT only, because there is no route on production for them to reach. A91, the one High finding against the MCP connector, is consequently not exploitable on production today; it is a live, UAT-only exposure until the connector is enabled there. Enabling the connector in production is gated on Finexer's written design sign-off (board item F1, open); that gate is separate from, and does not substitute for, fixing and retesting A91 itself first.

8. Remediation SLA and timeline

Remediation targets are SECURITY.md section 3a's bands, reproduced here for this report's own findings:

Severity	Acknowledge	Remediate or mitigate
Critical (P1)	Within 24 hours	Within 72 hours (a temporary mitigation counts, if the exposure genuinely stops)
High (P2)	Within 3 business days	Within 14 days
Medium (P3)	Within 5 business days	Within 30 days, or the next scheduled dependency/release cycle if sooner
Low (P4)	Best effort	Best effort, tracked on TODO.md , not silently dropped

All four original High findings (A82, A83, A84, A91) were acknowledged the same day they were found (2026-09-20/21) and fixed on main by 2026-09-22, comfortably inside the 14-day remediate target measured from acknowledgement. That target is about a fix existing and merged; it is not itself satisfied by deployment or retest, which this report tracks separately (see section 5).

A121, the fifth High finding, was found and acknowledged on 2026-09-27 and its fix was integrated on main on 2026-09-29, inside its own 14-day target, which runs from that date and not from 2026-09-20/21. The fix first shipped in release-20261001-2038 and was retested on device on 2026-10-04 (A60-2026-10-04).

Timeline, in order:

- A110** (trusted-proxy hop handling) was done on 2026-09-24; it resolved the two-ingress-path ambiguity (Vercel-fronted web traffic versus the mobile apps' direct Railway calls) that blocked releasing A92's rate-limit fix safely to production.
- Production release** of the four original High findings (release-20260927-0947 , 2026-09-27) and of the eleven first-round Medium and Low fixes, which are ancestors of the same tag (A112 retested the later release-20260927-1844 build).

3. **Retest** of those fifteen fixes ran the same day (board item A112, docs/security/pentest-runs/A112-2026-09-27/). The destructive API-15 step (A82, A83's disconnect-before-delete half, A84) was Blocked by an already-expired test credential and remains source-confirmed only; see section 6.
4. **Device-round fixes.** A118, A120, A121, A122 and the follow-up A123 were integrated on main on 2026-09-29 and first shipped in release-20261001-2038 . The on-device retest of A120, A121 and A122 ran on 2026-10-04 (A60-2026-10-04), against production releases decd7938 and c34332b6 .
5. **Still open:** A73, A77, A79, A81, A94 and A106 (none is High or Critical, so none blocks anything above), and the follow-ups A129 and A138. Their current state is on the board and is not restated here.

9. Testing approach

This is an internal security assessment performed by AURIQ LTD, under the rules-of-engagement record signed by Kevin on 2026-09-20 (docs/security/pentest-runs/roe-record.md). The work packages were run by this project's own Claude and Codex agent sessions against the scope in docs/security/pentest-scope-2026-09.md ; the device packages (WP7b, WP8) and the 2026-10-04 retest were performed by Kevin on his own phones, guided and recorded by a Claude session. Scope, numeric caps and stop conditions are in section 2 and in the rules-of-engagement record. What was not tested in this round, and why, is listed in section 6; those items are carried as Blocked or Not tested, never as passed.

10. Sign-off and revision history

Sign-off. The underlying internal testing programme (SECURITY.md section 3b) was signed off by Kevin, 2026-09-21, given as a written attestation in a working session with Claude ("Happy to sign this"), not a handwritten or cryptographic signature. This report, as a document, has not separately been signed by Kevin as of 2026-10-04.

WP12 review: pending. A separate Claude reviewer agent audits the evidence behind this report before it is treated as final. That step has not yet run; this line is replaced with its outcome and date when it does. The Codex half of the WP12 cross-model review was dropped, as recorded in section 4 (Kevin decision, 2026-10-04).

Revision history.

Version	Date	Change
v0.1 (DRAFT)	2026-09-23	First draft, produced for Finexer ahead of production release, retest and WP12; covers the 10 of 12 work packages executed 2026-09-20 to 2026-09-21
v0.1 (DRAFT, updated)	2026-09-27	A117: this Markdown updated in place to record WP7b (A55) and WP8 (A56) dynamic device testing, executed live 2026-09-27; coverage corrected from 10 of 12 to 12 of 12 work packages (to the extent possible without a Mac or a rooted device); five findings folded into section 5 (A118, A119, A120, A121, A122); headline corrected to five High findings, since A121 (iOS biometric-lock bypass) was not yet remediated
v0.1 (DRAFT, updated)	2026-09-28	A117 correction: the earlier text stated that none of the four original High findings (A82, A83, A84, A91) had reached production and that no production retest had run; both were false by 2026-09-27 evening. All four shipped to production 2026-09-27 and were retested the same day (board item A112, docs/security/pentest-runs/A112-2026-09-27/). Section 5 corrected to record A112's actual outcome per finding. Also corrected a stale claim that A92's release gate, board item A110, was still in progress
v1.0 candidate	2026-10-04	A60: final consolidated report. Records the 2026-10-04 on-device retest (docs/security/pentest-runs/A60-2026-10-04/): A120, A121 and A122 remediated and retested on both phones; A118 server-side revocation in production with the on-device residue re-check not yet run; A119 closed (debug build only). Section 5's Medium and Low tables updated with A112's 2026-09-27 retest outcomes. Follow-ups A123, A129 and A138 recorded. Section 9 rewritten as a plain testing-approach statement. WP12 recorded as a Claude-only review, the Codex half dropped (Kevin decision, 2026-10-04). "WP12 review: pending" until the reviewer's audit is recorded. PDF and HTML regenerated